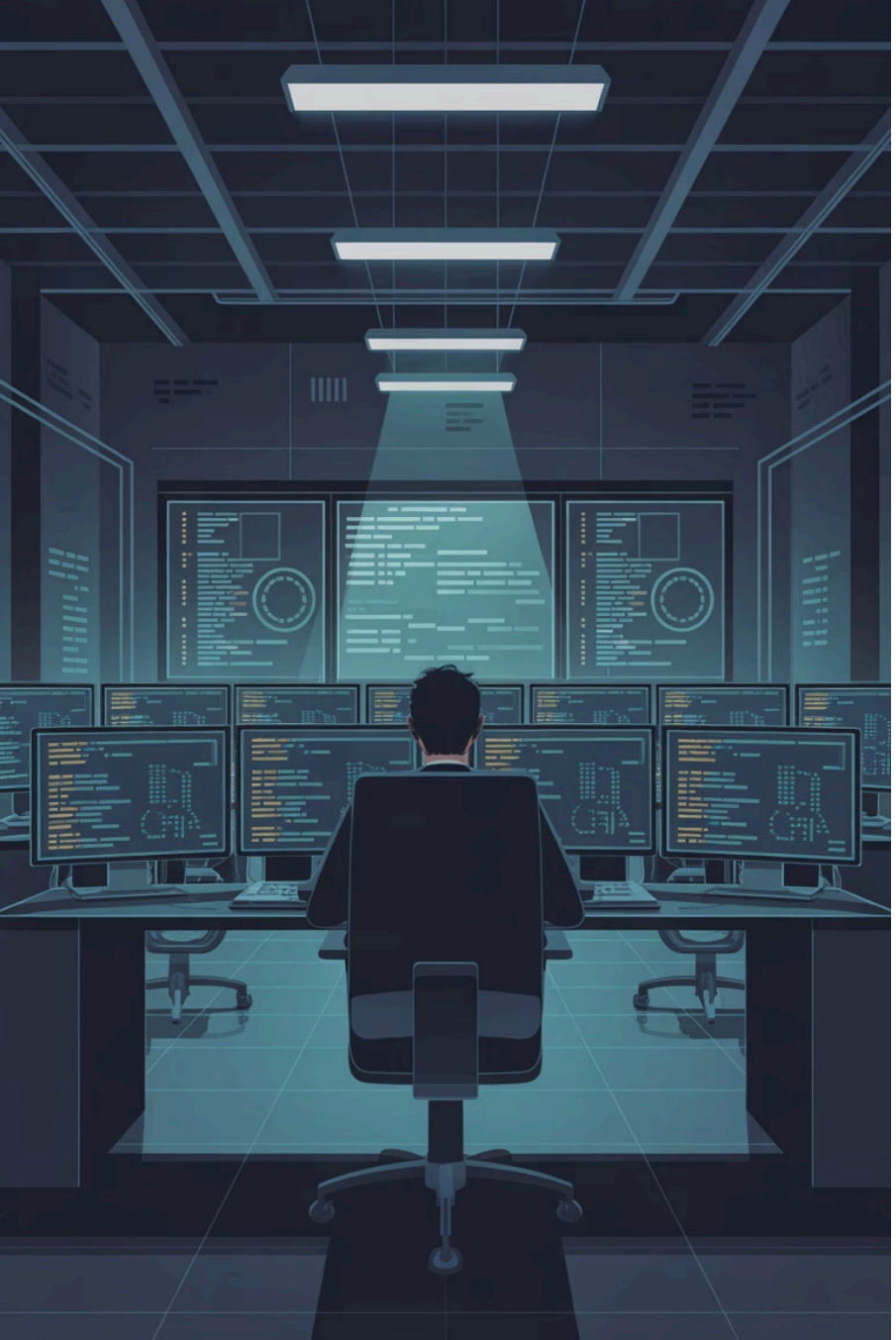


OFFENSIVE SECURITY RESEARCH

MITRE ATT&CK® T1566.001

Full-Cycle Phishing Attack Simulation

Focus: Infrastructure Weaponization & Credential Exfiltration

Environment: Controlled Educational Lab - John Bryce

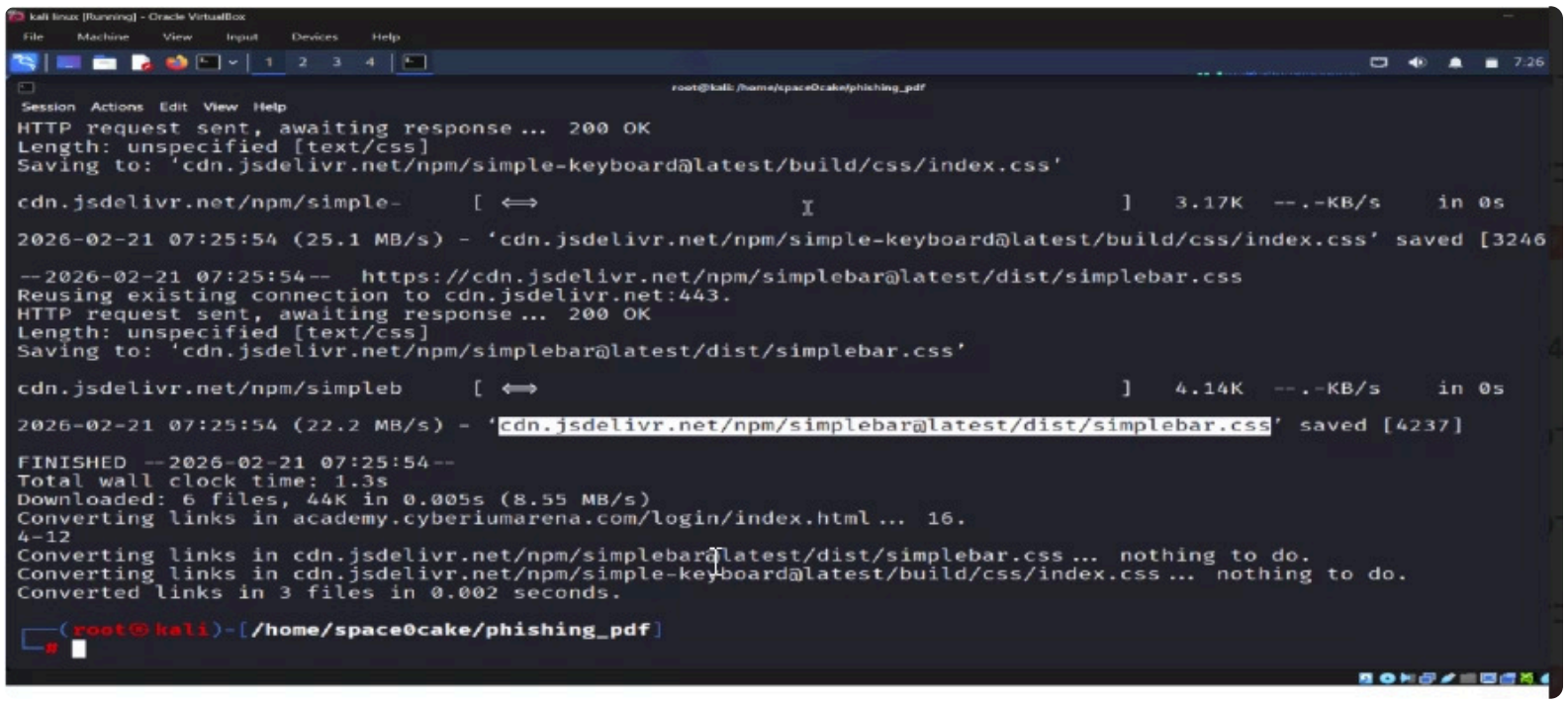
Instructor: David Shifman, Red Team Expert Program

Tech Stack: Kali Linux | Wget | PHP Backend | SSL/TLS | .htaccess

Executive Summary

Objective: Executed a full-cycle phishing simulation to demonstrate credential harvesting in a controlled lab environment.

- **Methodology:** Leveraged high-fidelity page cloning via wget and custom PHP integration for data exfiltration.
- **Security Layer:** Implemented SSL/TLS encryption and protocol enforcement via .htaccess to maximize attack credibility.



⚠️ This project was conducted in a **controlled, legal educational environment** with explicit authorization.

METHODOLOGY

Attack Methodology Overview

The engagement followed a structured five-phase kill chain, progressing from reconnaissance through validated proof of concept.

Recon & Setup

Domain spoofing and infrastructure provisioning

Weaponization

High-fidelity page cloning via wget

Exfiltration

Backend integration and credential capture

Trust Layer

SSL/TLS and HTTPS enforcement

Validation

End-to-end proof of concept

PHASE I

Reconnaissance & Environment Setup

The initial phase focused on acquiring a deceptive domain and preparing backend infrastructure to support the attack.

Domain Acquisition

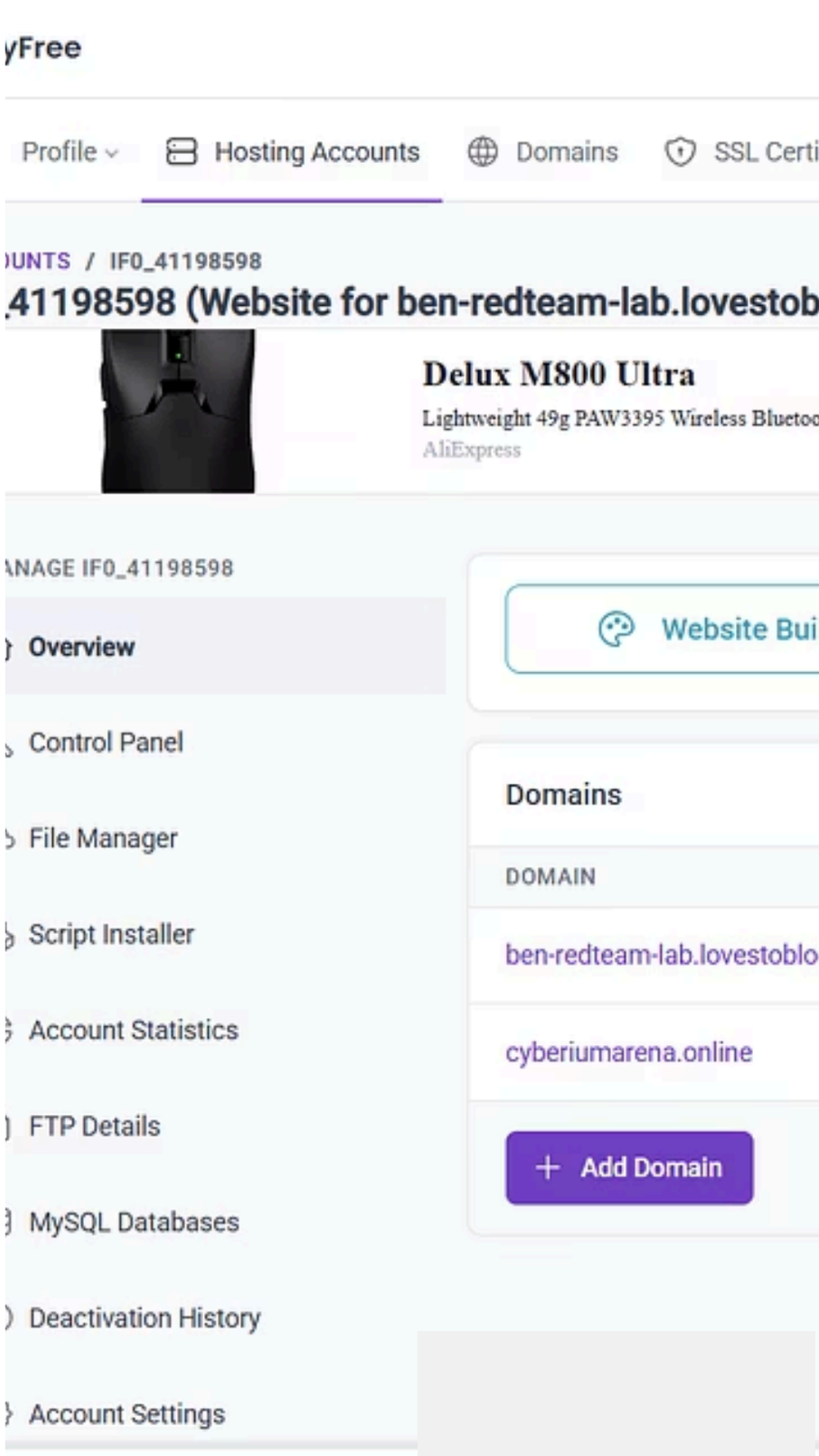
Registered `cyberiumarena.online` to mirror the target environment and maximize visual credibility

Hosting Infrastructure

Leveraged InfinityFree hosting to establish a persistent web server for the phishing assets

DNS Configuration

Synchronized Nameservers (NS) and established a custom addon domain to link the registrar with the hosting platform



PHASE II

Advanced Page Cloning & Weaponization

```
→  phishing_project ls
 academy.cyberiumarena.com   cdn.jsdelivr.net   www.gstatic.com
```

High-Fidelity Mirroring

Using the `wget` utility, the target's login page was cloned with pixel-perfect accuracy:

```
wget -E -H -k -K -p --no-check-certificate [Target URL]
```

Technical optimization flags ensured:

- All CSS, images, and internal links were localized
- Offline stability and full visual consistency
- No broken assets or external dependencies

PHASE III

Backend Integration & Data Interception

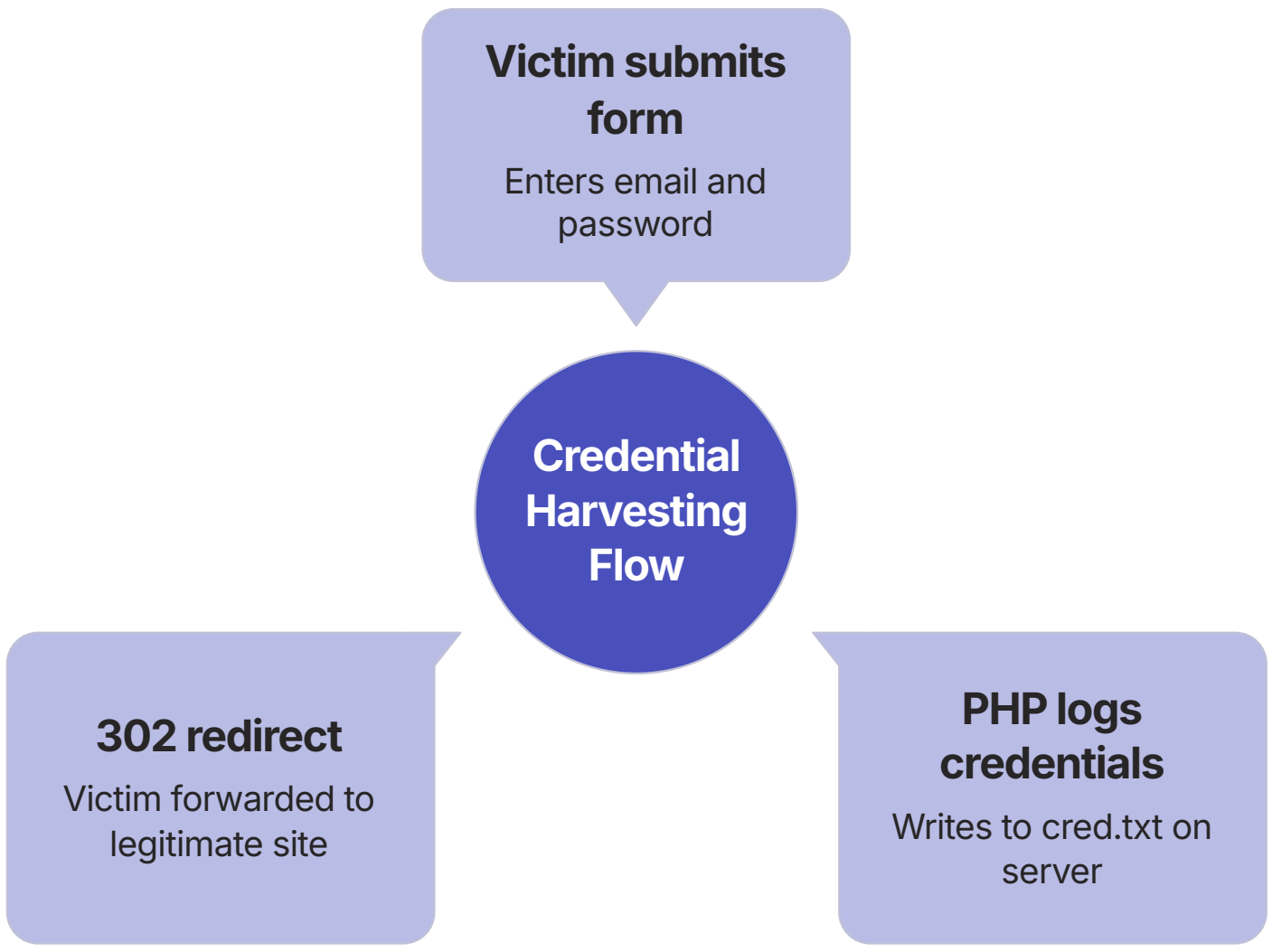
The cloned HTML was modified to intercept user input and redirect the victim to the legitimate site — minimizing suspicion and maximizing dwell time.

Form Manipulation

Identified email and password parameters in the source code. Redirected the form action to a custom `login.php` script for interception.

Data Capture

Developed a PHP backend to log intercepted credentials into a secured `cred.txt` file while executing a **302 Redirect** to the authentic platform.



PHASE IV

Establishing Trust & Security Persistence

To bypass modern browser warnings and increase the social engineering success rate, several trust-building layers were implemented.

1

SSL/TLS Implementation

Configured a valid TLS certificate via the hosting provider's certificate manager using **CNAME record verification**.

2

Protocol Enforcement

Implemented a `.htaccess` file to force HTTPS (Port 443), ensuring the padlock icon appears in the victim's browser.

3

DNS Configuration

Synchronized nameservers between the registrar and hosting provider for seamless, trustworthy domain resolution.

PHASE V

Validation & Proof of Concept

A successful end-to-end simulation was performed in an incognito browser environment, confirming full attack chain execution.

01

Victim Navigation

User navigates to the malicious URL — no browser warnings triggered

02

Credential Input

Credentials entered into the spoofed UI, visually indistinguishable from the real login

03

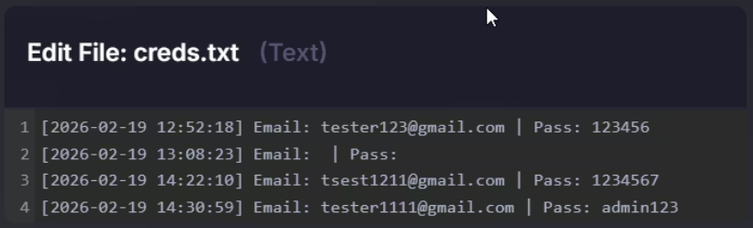
Seamless Redirection

User is transparently transitioned to the authentic `academy.cyberiumarena.com`

04

Exfiltration Confirmed

`cred.txt` successfully captured plain-text credentials — full chain validated



⚠ FINDINGS & MITIGATION

Key Findings & Recommended Mitigations

🔴 Critical Findings

- **SSL alone is insufficient** — a padlock icon does not guarantee legitimacy
- **Page cloning is trivially easy** — modern tools replicate UIs in seconds
- **Credential capture is silent** — victims experience zero interruption
- **Domain lookalikes bypass casual inspection** by most end users

🟢 Mitigations

- **MFA enforcement** — renders stolen credentials insufficient
- **Security awareness training** — teach URL inspection habits
- **Domain monitoring** — detect and takedown lookalike registrations
- **Browser-based phishing protection** — deploy anti-phishing extensions
- **FIDO2/WebAuthn** — phishing-resistant authentication

Conclusion & Takeaways

This engagement proves that a convincing phishing attack can be stood up with **minimal cost and effort** — underscoring the critical importance of layered defenses.

Trust Is Exploitable

SSL certificates and professional UI create a false sense of security

Humans Are the Vector

Technical controls must be paired with continuous awareness training

Defense in Depth Wins

MFA, monitoring, and phishing-resistant auth close the gap